

Содержание

Введение	6
1 Аналитическая часть	8
1.1 Интервью с заказчиком	8
1.2 Описание предметной области	10
1.3 Описание механизмов защиты от утечки информации	12
1.4 Анализ представленных на рынке устройств инженерно-технической защиты информации	13
1.5 Анализ требований к безопасности	15
1.6 Нормативно-правовые аспекты внедрения средств защиты информации	16
1.7 Анализ рынка программно-аппаратных средств защиты информации	17
2 ТЕХНОЛОГИЧЕСКАЯ ЧАСТЬ	19
2.1 Настройка и администрирование защиты уровня доступа компьютерной сети	19
2.2 Настройка и администрирование защиты уровня распределения компьютерной сети с использованием WebSocket Secure	21
2.3 Настройка и администрирование защиты уровня ядра компьютерной сети с динамической блокировкой IP	23
2.4 Настройка безопасности сервера Ubuntu 24 с внедрением Mistral Server, Semgrep, Trivy и ИИ-агента	26
2.5 Оценка эффективности средств защиты с помощью Semgrep, Trivy и симулятора атак Mistral Demo	30
3. ЭКОНОМИЧЕСКАЯ ЧАСТЬ	36
3.1 Общие затраты на разработку СБ	36
3.2 Расчет затрат на выплату работникам	37
3.2.1 Расчет затрат на выплату работникам на этапе разработки проекта и документации	37
3.2.2 Расчет затрат на выплату работникам на этапе разработки приложения	39
3.2.3 Расчет затрат на выплату работникам на этапе тестирования безопасности приложения	40
3.3 Расчет общих затрат на выплату работникам	41
3.4 Расчет затрат на приобретение программного обеспечения	41
3.5 Расходы на страховые взносы	42
3.6 Общие затраты на разработку СБ	42
Заключение	44
Библиографический список	46

					КТЗС.ДП.БП412.07 ПЗ								
Изм.	Лист	№ докум.	Подпись	Дата									
Разраб.		Ивашкин Д.А.			Обеспечение информационной безопасности ООО «Ремон Девелопер»				Лит.	Лист	Листов		
Провер.		Ярмухамедов А.Р.									2	48	
Провер.									Омавиат				
Н.Контр		Башанов Н.Е.											
Утверд.		Пожерукова Е.Б.											

Приложение А.....	49
Приложение Б	50
Приложение В.....	51
Приложение Г	52
Приложение Д.....	53
Приложение Е.....	54

					КТЗС.ДП.БП412.07 ПЗ	Лист
						3
Изм.	Лист	№ докум.	Подпись	Дата		

Список условных обозначений и сокращений

APM	Автоматизированное рабочее место
СУБД	Система управления базой данных
SIEM	Security Information and Event Management (Система управления событиями информационной безопасности).
SSH	Secure Shell (Протокол защищенного удаленного управления сервером).
Trivy	Комплексный сканер уязвимостей с открытым исходным кодом для контейнеров, файловых систем и репозитория кода.
Semgrep	Инструмент статического анализа кода (SAST) для автоматического поиска ошибок, уязвимостей.
Ubuntu 24 LTS	Версия операционной системы на базе ядра Linux.
Raemon (Remon)	Сайт ООО «Ремон Девелопер»
WebSocket Secure / WSS	Защищенный протокол полнодуплексного обмена данными в реальном времени (поверх TLS/SSL).
Mistral Demo	Демонстрационное приложение или тестовая среда для демонстрации возможностей нейросетевой языковой модели Mistral.
Mistral Server	Серверная часть программного комплекса, обеспечивающая хостинг модели Mistral и обработку поступающих к ней запросов.
Mistral Client	Клиентская часть (интерфейс), отправляющая запросы к Mistral Server и отображающая полученные от него ответы.
IP	Internet Protocol (Межсетевой протокол, базовый протокол сетевого уровня).
JSON	(JavaScript Object Notation) Простой текстовый формат обмена данными.
REST	Representational State Transfer (Архитектурный стиль взаимодействия компонентов распределенного приложения в сети).

SSH	Сетевой протокол для безопасного удаленного управления сервером
DDoS	(Distributed Denial of Service) Распределенная атака типа «отказ в обслуживании», направленная на исчерпание ресурсов целевой системы множеством запросов.
SSL	Secure Sockets Layer (Криптографический протокол, обеспечивающий безопасную связь. В настоящее время вытеснен более современным протоколом TLS).
API	(Application Programming Interface) — Программный интерфейс приложения, набор правил и способов взаимодействия между различными программами).
CPU	(Central Processing Unit) — Центральный процессор
GPU	(Graphics Processing Unit) — Графический процессор)
MTTD	Mean Time To Detect (Среднее время обнаружения угрозы).
MTTR	Mean Time To Respond (Среднее время автоматического реагирования системы).
UFW	Uncomplicated Firewall (Инструмент для управления межсетевым экраном в ОС Linux).
NVD	National Vulnerability Database (Национальная база данных уязвимостей).
WAF	Web Application Firewall (Защитный экран уровня веб-приложений).
JSON	JavaScript Object Notation (Простой текстовый формат обмена данными).
DEFCON	Defense Readiness Condition (Шкала оценки готовности; в проекте — индекс уровня угрозы хоста).

Введение

Информационные технологии занимают важное место в деятельности современных коммерческих организаций. Использование вычислительных сетей, веб-порталов и информационных систем позволяет автоматизировать процессы взаимодействия с клиентами, хранения и обработки корпоративных данных. Одновременно с развитием информационных технологий возрастает количество угроз, связанных с несанкционированным доступом к информации, утечкой данных, нарушением работоспособности веб-ресурсов и воздействием вредоносного программного обеспечения.

В современной индустрии информационной безопасности классические средства защиты постепенно уступают место концепциям активного обнаружения и автоматизированного реагирования на инциденты. Особую актуальность приобретает задача интеллектуального анализа массивов системных событий, так как традиционные методы ручного мониторинга оказываются неэффективными в условиях высоких нагрузок.

Объектом исследования является информационная инфраструктура и веб-ресурсы компании ООО «Ремон Девелопер».

Предметом исследования являются методы и программные средства обеспечения активного мониторинга, выявления уязвимостей и противодействия угрозам информационной безопасности с применением технологий генеративного искусственного интеллекта.

Целью дипломного проекта является разработка программного комплекса, предназначенного для централизованного сбора телеметрии, проведения интеллектуального анализа инцидентов и автоматизированного реагирования на угрозы в инфраструктуре предприятия.

Для достижения поставленной цели необходимо решить следующие задачи:

					КТЗС.ДП.БП412.07 ПЗ	Лист
						6
Изм.	Лист	№ докум.	Подпись	Дата		

- провести анализ предметной области и инфраструктуры предприятия;
- выполнить анализ существующей системы безопасности;
- определить основные угрозы и сформировать требования к средствам защиты;
- разработать архитектуру и реализовать программный комплекс защиты (управляющий сервер и автоматизированное рабочее место оператора);
- интегрировать модуль искусственного интеллекта для расследования инцидентов;
- провести анализ эффективности предложенного решения на основе тестовых сценариев атак.

Практическая значимость работы заключается в снижении нагрузки на специалиста по информационной безопасности, повышении скорости реакции на «киберинциденты» и минимизации рисков компрометации данных предприятия за счет внедрения средств автоматизированного анализа.

Работа выполнена на основе действующей нормативной документации: ГОСТ Р 59639-2021, ГОСТ Р 59588-2021, СП 256.1325800.2023, а также учебных и научно-практических материалов в области технической защиты информации.

Основанием для разработки данного дипломного проекта является приказ директора БПОУ ОО «Омский авиационный колледж им. Н.Е. Жуковского» №349-ОД от «28» апреля 2026 года.

					КТЗС.ДП.БП412.07 ПЗ	Лист
						7
Изм.	Лист	№ докум.	Подпись	Дата		

1 Аналитическая часть

1.1 Интервью с заказчиком

Для создания эффективной системы обеспечения информационной безопасности необходимо провести интервьюирование заказчика, в ходе которого будут определены основные требования к разрабатываемому программному комплексу.

В ходе интервьюирования с представителем компании ООО «Ремон Девелопер» были озвучены следующие вопросы и получены ответы:

Вопрос 1. Какова основная деятельность вашей организации?

Ответ: Наша компания занимается строительством и реализацией объектов недвижимости. Основным инструментом взаимодействия с клиентами является наш крупный корпоративный веб-портал, через который осуществляются консультации, прием заявок и предоставление информации об объектах.

Вопрос 2. Как устроена ваша ИТ-инфраструктура и кто отвечает за её безопасность?

Ответ: Наша организация имеет распределенную структуру, так как наши представительства открыты в трех разных городах. В каждом филиале функционируют собственные локальные сети и серверное оборудование для обеспечения внутренних нужд. При этом наш главный внешний ресурс — корпоративный веб-портал и централизованная база данных клиентов — развернут отдельно на едином выделенном сервере под управлением операционной системы Ubuntu 24 LTS. В штате компании предусмотрена лишь одна должность специалиста по информационной безопасности. Физически контролировать всю распределенную сеть силами одного человека невозможно, поэтому на данном этапе перед вами поставлена конкретная задача: обеспечить надежный мониторинг и защиту именно этого центрального сервера, на котором функционирует сайт, так как он открыт для внешней сети Интернет и подвержен наибольшему числу деструктивных воздействий.

					КТЗС.ДП.БП412.07 ПЗ	Лист
						8
Изм.	Лист	№ докум.	Подпись	Дата		

Вопрос 3. В чем заключается главная проблема существующего подхода к защите данного веб-ресурса?

Ответ: Главная проблема — это колоссальный объем системных журналов (записей о событиях) и метрик нагрузки, генерируемых веб-порталом и операционной системой сервера. Специалист вынужден анализировать эти разрозненные данные вручную. При возникновении сложных или распределенных атак (например, попыток внедрения вредоносного кода в веб-формы или массового подбора паролей к административной панели) времени на сопоставление фактов и ручной поиск источника угрозы уходит слишком много, что влечет за собой риски простоя сайта и финансовых потерь для бизнеса.

Вопрос 4. Чего вы ожидаете от новой системы безопасности?

Ответ: Нам требуется единое автоматизированное рабочее место (программное обеспечение) для нашего единственного специалиста. Система должна в реальном времени собирать все системные события с защищаемого веб-сервера в единую картину и распределять их по уровню опасности. Самое главное требование — наличие интеллектуального программного агента (на базе искусственного интеллекта), который будет видеть полный контекст происходящих на сервере инцидентов, анализировать их и предлагать оператору готовые решения для защиты, вплоть до автоматической блокировки источника атаки на уровне сетевого экрана.

Вопрос 5. Каков бюджет, выделенный на реализацию проекта?

Ответ: Бюджет ограничен и составляет не более 144 519,40 рублей. Приоритет отдаётся надёжным и сертифицированным решениям с оптимальным соотношением цены и эффективности защиты. Срок реализации — не более трёх месяцев.

Вопрос 5. Планируется ли в дальнейшем масштабирование разработанного программного комплекса на локальные сети остальных филиалов компании?

					КТЗС.ДП.БП412.07 ПЗ	Лист
						9
Изм.	Лист	№ докум.	Подпись	Дата		

Ответ: Да, в долгосрочной перспективе, после успешного тестирования и опытной эксплуатации комплекса на центральном сервере под управлением операционной системы Ubuntu 24, мы планируем адаптировать данное решение для мониторинга локальных вычислительных сетей в остальных филиалах. Поэтому архитектура программного средства должна быть гибкой и изначально предусматривать возможность последующего расширения функционала без коренной переработки ядра системы.

1.2 Описание предметной области

Общество с ограниченной ответственностью «Ремон Девелопер» является коммерческой организацией, осуществляющей деятельность в сфере девелопмента, строительства и реализации жилой и коммерческой недвижимости. Организация обладает территориально распределенной структурой и включает в себя представительства, открытые в трех различных городах Российской Федерации.

Информационная инфраструктура предприятия спроектирована с учетом необходимости обеспечения непрерывного взаимодействия между удаленными подразделениями и обслуживания внешних клиентов. В каждом из трех филиалов развернуты локальные вычислительные сети, включающие в себя рабочие станции сотрудников, внутреннее коммуникационное оборудование и служебные локальные серверы, предназначенные для решения внутрикорпоративных задач и обеспечения документооборота подразделений.

Основным инструментом ведения бизнеса, привлечения клиентов и обеспечения прозрачности операций является официальный корпоративный веб-портал ООО «Ремон Девелопер». Данный веб-ресурс, совмещенный с централизованной базой данных, функционирует обособленно на едином выделенном сервере под управлением операционной системы Ubuntu 24. Веб-портал выполняет следующие ключевые функции в рамках информационных процессов организации:

					КТЗС.ДП.БП412.07 ПЗ	Лист
						10
Изм.	Лист	№ докум.	Подпись	Дата		

- предоставление актуальной информации об объектах недвижимости,
- архитектурных решениях и этапах строительства;
- обеспечение работы интерактивных сервисов (личный кабинет клиента,
- формы обратной связи, калькуляторы стоимости);
- сбор, обработку и хранение входящих заявок, персональных данных
- клиентов и сопутствующих конфиденциальных сведений.

Централизованный характер размещения веб-портала на операционной системе Ubuntu 24 накладывает особую ответственность на технический персонал, так как данный сервер открыт для внешней сети Интернет и постоянно подвергается деструктивным воздействиям, включая автоматизированное сканирование уязвимостей, попытки внедрения вредоносного программного кода и распределенные атаки, направленные на отказ в обслуживании.

Штатное расписание компании предусматривает наличие только одного специалиста по информационной безопасности. В обязанности данного сотрудника входит контроль защищенности всей распределенной инфраструктуры, включая локальные сети филиалов, а также обеспечение безопасности и отказоустойчивости центрального веб-сервера.

Основная специфика рассматриваемой предметной области заключается в возникновении критического дисбаланса между колоссальным объемом циркулирующей технической информации (системных журналов веб-сервера, журналов авторизации операционной системы, сетевых метрик производительности) и ограниченными возможностями человеческого ресурса по ее обработке. Единственный специалист физически не способен осуществлять непрерывный круглосуточный мониторинг распределенных потоков данных. В связи с

					КТЗС.ДП.БП412.07 ПЗ	Лист
						11
Изм.	Лист	№ докум.	Подпись	Дата		

этим возникает необходимость сужения области непосредственной защиты на первом этапе внедрения средств автоматизации и концентрации усилий на наиболее уязвимом узле — центральном сервере под управлением Ubuntu 24.

Таким образом, предметная область характеризуется высокой потребностью в разработке и внедрении легковесного, экономически эффективного и централизованного программного средства. Данное решение должно агрегировать информацию о состоянии защищенности сервера, преобразовывать разрозненные записи журналов событий в единую картину инцидентов и предоставлять автоматизированную интеллектуальную поддержку оператору для минимизации рисков успешного проведения кибератак.

1.3 Описание механизмов защиты от утечки информации

Обеспечение конфиденциальности и предотвращение утечек защищаемой информации, включая персональные данные клиентов, базу учетных записей сотрудников, финансовые показатели и исходный код веб-портала, является приоритетной задачей безопасности ООО «Ремон Девелопер» и реализуется на базе центрального сервера под управлением операционной системы Ubuntu 24. В настоящее время на объекте задействован комплекс базовых мер, включающий ролевую модель разграничения доступа в ОС, запуск прикладных процессов от имени низкопривилегированных учетных записей и ограничение удаленного администрирования защищенным протоколом SSH с аутентификацией по криптографическим ключам.

Сетевой периметр сервера контролируется локальным межсетевым экраном, функционирующим по принципу минимизации доступных портов, где для внешних запросов открыты только стандартные интерфейсы веб-портала (порты 80 и 443), а доступ к технологическим сокетам управления и СУБД полностью заблокирован для внешних адресов. Транспортировка конфиденциальных сведений осуществляется исключительно по

					КТЗС.ДП.БП412.07 ПЗ	Лист
						12
Изм.	Лист	№ докум.	Подпись	Дата		

зашифрованному протоколу HTTPS с применением современных протоколов TLS, что нивелирует риски перехвата трафика в открытых каналах связи, в то время как разграничение прав внутри самого веб-приложения поддерживается механизмами токенизированной аутентификации сессий сотрудников. Организационный контур защиты дополняется утвержденными регламентами регулярного резервного копирования, внутренними инструкциями по работе с конфиденциальными сведениями и подписанными обязательствами персонала о неразглашении коммерческой тайны.

Несмотря на комплексность, существующие средства носят исключительно статический характер и обеспечивают защиту преимущественно на сетевом и системном уровнях, оставляя уязвимым прикладной уровень. Действующие механизмы способны блокировать неиспользуемые порты, но не обладают инструментами непрерывного интеллектуального и контентного анализа для обнаружения деструктивных воздействий, передаваемых злоумышленниками внутри легитимных HTTP-запросов через открытые порты под видом действий обычных пользователей. Данное обстоятельство создает высокие риски обхода статических барьеров и напрямую обуславливает необходимость модернизации системы безопасности предприятия посредством разработки специализированного программного комплекса, способного осуществлять активный мониторинг и динамическое противодействие актуальным угрозам в режиме реального времени.

1.4 Анализ представленных на рынке устройств инженерно-технической защиты информации

Проведенный аудит существующей системы информационной безопасности ООО «Ремон Девелопер» показал, что применяемые на предприятии базовые механизмы защиты обеспечивают лишь минимально необходимый уровень конфиденциальности и целостности данных. В ходе обследования инфраструктуры центрального сервера под управлением

					КТЗС.ДП.БП412.07 ПЗ	Лист
						13
Изм.	Лист	№ докум.	Подпись	Дата		

операционной системы Ubuntu 24 был выявлен ряд критических архитектурных и организационных недостатков, существенно снижающих общую защищенность объекта. Главной уязвимостью текущего контура является высокая децентрализация и фрагментация событий безопасности, поскольку системные журналы веб-сервера, СУБД и подсистем авторизации собираются разрозненно и хранятся в неструктурированном виде, исключая возможность оперативного выявления сложных многоступенчатых кибератак из единой точки агрегации телеметрии. Ситуация усугубляется выраженным реактивным подходом к мониторингу в условиях дефицита кадровых ресурсов, когда при высоких объемах сетевого трафика единственный штатный специалист подвергается информационной перегрузке и теряет техническую возможность своевременно анализировать логи и внедрять блокирующие правила в межсетевой экран при интенсивных атаках класса Brute Force на службу SSH.

Кроме того, в организации полностью отсутствует контроль жизненного цикла безопасной разработки, из-за чего процесс обновления корпоративного веб-портала не сопровождается автоматизированным SAST-аудитом исходного кода и проверкой зависимостей, создавая постоянный риск проброса критических уязвимостей типа SQL-инъекций и XSS непосредственно в производственную среду. Этот изъян дополняется отсутствием автоматизированных систем поддержки принятия решений, заставляя оператора полагаться исключительно на собственный опыт при расследовании инцидентов, что критически увеличивает среднее время реагирования на угрозы и повышает вероятность совершения человеческой ошибки.

На основании проведенного анализа установлена явная необходимость модернизации контура защиты компании и внедрения качественно нового решения — интегрированного программного комплекса класса SOAR/SIEM. Данная система должна обеспечить централизованный сбор системной телеметрии, автоматизацию контроля программных

уязвимостей средствами Sengrep и Trivy, а также применение технологий искусственного интеллекта для автономного анализа и жесткой блокировки инцидентов информационной безопасности в режиме реального времени.

1.5 Анализ требований к безопасности

С учетом специфики деятельности предприятия, выявленных недостатков существующей инфраструктуры и ограниченности кадровых ресурсов, к разрабатываемому программному комплексу защиты предъявляются следующие основные требования.

Функциональные требования:

1. Централизованный сбор данных: система должна обеспечивать непрерывный сбор системных журналов, телеметрии веб-портала и метрик аппаратной нагрузки (использование центрального процессора, оперативной памяти, сетевых соединений) с целевого сервера под управлением операционной системы Ubuntu 24 в режиме реального времени.

2. Единое рабочее пространство: требуется разработка специализированного программного обеспечения — автоматизированного рабочего места (АРМ) специалиста по информационной безопасности. Интерфейс должен консолидировать разрозненные данные и отображать текущий уровень угрозы.

3. Интеллектуальный анализ: ключевым требованием является интеграция модуля генеративного искусственного интеллекта. Данный модуль должен обладать возможностью семантического анализа содержимого системных журналов для выявления сложных векторов атак (например, попыток внедрения SQL-кода), классифицировать инциденты по уровню критичности и предлагать оператору инструкции по их нейтрализации.

4. Автономное реагирование: программный комплекс должен быть способен к автоматическим защитным действиям. При фиксации серии критических инцидентов с одного сетевого адреса система обязана

					КТЗС.ДП.БП412.07 ПЗ	Лист
						15
Изм.	Лист	№ докум.	Подпись	Дата		

самостоятельно формировать и применять правила блокировки на уровне межсетевого экрана операционной системы сервера, минимизируя время реакции на угрозу.

Технические и экономические требования:

1. Низкое потребление ресурсов: фоновые службы сбора данных не должны создавать избыточную вычислительную нагрузку на защищаемый сервер, чтобы не нарушать работоспособность основного веб-портала компании.

2. Масштабируемость: архитектура комплекса должна закладывать фундамент для будущего расширения — подключения к системе мониторинга локальных вычислительных сетей филиалов организации в других городах.

3. Финансовые ограничения: себестоимость внедрения и эксплуатации разрабатываемого программного комплекса не должна превышать выделенный бюджет в размере 144 519,40 рублей.

1.6 Нормативно-правовые аспекты внедрения средств защиты информации

Обеспечение информационной безопасности в ООО «Ремон Девелопер» осуществляется в строгом соответствии с законодательством Российской Федерации, регламентирующим процессы обработки, хранения и защиты информации. Разработка и внедрение любых новых программных комплексов мониторинга должны опираться на действующую нормативно-правовую базу.

Фундаментальным нормативным правовым актом в данной сфере является Федеральный закон от 27 июля 2006 г. № 149-ФЗ «Об информации, информационных технологиях и о защите информации». Данный закон устанавливает обязательность соблюдения конфиденциальности информации, доступ к которой ограничен федеральными законами, а также определяет принципы защиты информационной инфраструктуры от

					КТЗС.ДП.БП412.07 ПЗ	Лист
Изм.	Лист	№ докум.	Подпись	Дата		16

неправомерного доступа, уничтожения, модифицирования или блокирования.

Поскольку целевой веб-портал компании осуществляет сбор данных клиентов в процессе оформления заявок на недвижимость, деятельность организации попадает под действие Федерального закона от 27 июля 2006 г. № 152-ФЗ «О персональных данных». В соответствии с требованиями статьи 19 указанного закона, оператор обязан принимать необходимые правовые, организационные и технические меры для защиты персональных данных от неправомерного или случайного доступа к ним, их уничтожения, изменения или копирования. Внедряемый программный комплекс защиты с функциями мониторинга и блокировки злоумышленников выступает прямой технической мерой исполнения требований данного закона.

При проектировании архитектуры системы и описании ее компонентов также учитываются положения национальных стандартов, в частности ГОСТ Р 50922-2006 «Защита информации. Основные термины и определения», который закрепляет единую терминологическую базу в области защиты информации.

Разрабатываемые механизмы автономного реагирования (автоматическая блокировка сетевых адресов) должны функционировать корректно и иметь механизмы защиты от ложных срабатываний, чтобы не нарушать конституционные права легитимных пользователей сети Интернет на свободный поиск и получение общедоступной информации, размещенной на веб-портале предприятия.

1.7 Анализ рынка программно-аппаратных средств защиты информации

Для обоснования целесообразности самостоятельной разработки был проведен анализ рынка средств защиты информации. Существующие крупномасштабные корпоративные платформы (например, MaxPatrol SIEM) обладают исчерпывающим функционалом, однако их применение в ООО «Ремон Девелопер» экономически и технически нецелесообразно.

					КТЗС.ДП.БП412.07 ПЗ	Лист
						17
Изм.	Лист	№ докум.	Подпись	Дата		

Стоимость их лицензирования многократно превышает целевой бюджет проекта (от 50 000 до 90 000 рублей), а эксплуатация требует выделенного штата аналитиков, тогда как на предприятии предусмотрен лишь один ИБ-специалист.

Альтернативный подход на базе интеграции разрозненных бесплатных утилит характеризуется полным отсутствием централизации. Необходимость ручного сопоставления логов из множества изолированных интерфейсов и самостоятельного принятия решений без аналитической поддержки критически увеличивает время реагирования оператора на динамичные кибератаки.

Анализ подтвердил дефицит централизованных легковесных систем для малого бизнеса. Разрабатываемый программный комплекс полностью закрывает эту потребность: интеграция модулей сбора телеметрии с ОС Ubuntu 24, консолидированного рабочего места и автономного ИИ-агента позволяет обеспечить надежную защиту инфраструктуры, компенсируя нехватку кадровых ресурсов строго в рамках заданных бюджетных ограничений.

2 ТЕХНОЛОГИЧЕСКАЯ ЧАСТЬ

2.1 Настройка и администрирование защиты уровня доступа компьютерной сети

В процессе проектирования и модернизации системы обеспечения информационной безопасности ИТ-инфраструктуры ООО «Ремон Девелопер» задача организации защиты уровня доступа (Access Layer) была решена путем развертывания комплексных эшелонов безопасности непосредственно на целевом хосте веб-ресурса. В рамках разрабатываемой архитектуры распределенного программного комплекса уровень доступа принимает на себя весь входящий трафик и является отправной точкой для сбора первичных событий безопасности. Логическая структура взаимодействия компонентов на уровне доступа хоста представлена на рисунке 1.

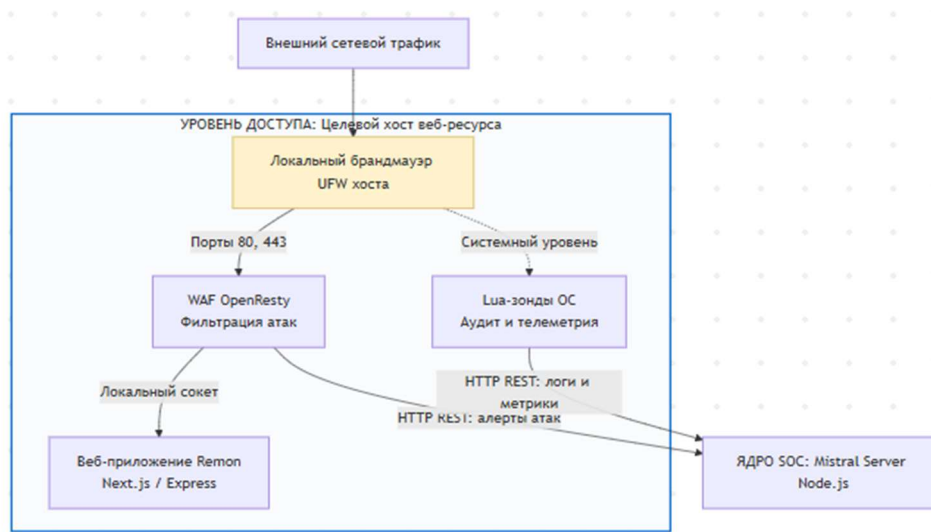


Рисунок 1 – Схема логической изоляции интерфейсов и сервисов на едином сервере

В соответствии с разработанной архитектурой проекта, на уровне доступа развернут отказоустойчивый стек, изолирующий конечное веб-приложение Remon от прямого воздействия внешней среды. Публичный сетевой интерфейс хоста открыт исключительно для шлюза Reverse Proxy на базе WAF OpenResty (порты 80 и 443). Использование встроенных Lua-скриптов внутри OpenResty позволяет проводить инспекцию HTTP-запросов на лету, выявляя сигнатуры таких веб-уязвимостей, как SQL-

Изм.	Лист	№ докум.	Подпись	Дата

инъекции (SQLi), межсайтовый скриптинг (XSS) и попытки обхода аутентификации. Само веб-приложение Remon функционирует внутри изолированного локального сокета (порт 3000) и принимает запросы только после их успешной валидации на WAF.

Параллельно на уровне доступа развернута группа автономных Lua-зондов телеметрии, осуществляющих непрерывный низкоуровневый аудит операционной системы. В их состав входят специализированные модули: monitor_network.lua для анализа сетевых сессий через утилиту ss, monitor_auth.lua для парсинга системных логов /var/log/auth.log на предмет брутфорса (фрагмент программного кода монитора представлен в приложении А), а также monitor_integrity.lua, контролирующий неизменность критических бинарных файлов по хэш-суммам SHA-256.

Управление сетевыми потоками на данном уровне возложено на локальный брандмауэр UFW, работающий в тесной связке со средствами динамического реагирования хоста. Алгоритм прохождения и предварительной фильтрации пакетов на внешнем интерфейсе уровня доступа детально отражен на рисунке 2.

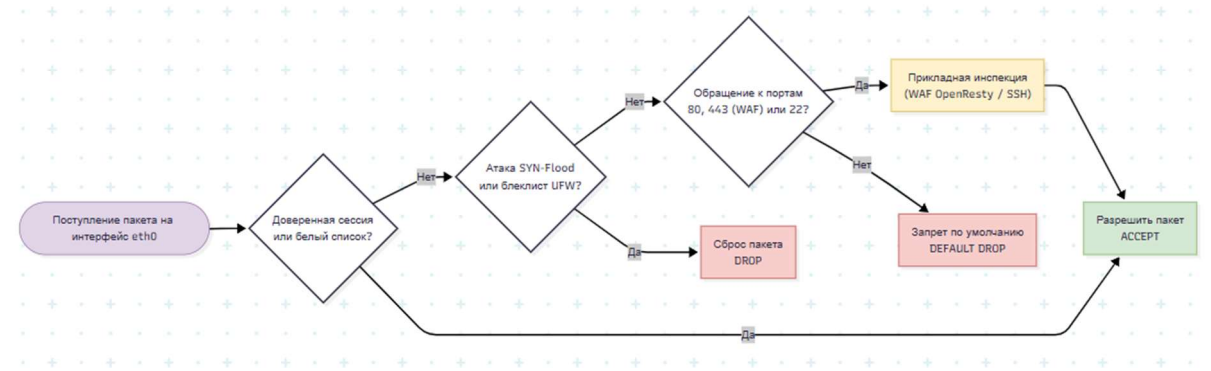


Рисунок 2 – Блок-схема алгоритма фильтрации входящего трафика локальным брандмауэром

Входящие пакеты первоочередно сверяются с таблицей динамических блокировок: трафик от ранее выявленных нарушителей немедленно сбрасывается (DROP). Доверенные сессии (ESTABLISHED) обрабатываются по ускоренному пути, а для новых соединений применяется политика полного запрета по умолчанию с доступом

исключительно к портам WAF OpenResty. Любые прямые запросы к внутренним службам (Mistral Server, СУБД) отсекаются.

Таким образом, модернизация уровня доступа сформировала жесткий контролируемый барьер в инфраструктуре ООО «Ремон Девелопер». Связка локального брандмауэра и WAF нейтрализует большинство атак до их проникновения в бизнес-логику целевого стенда Remon. В свою очередь, внедрение системных Lua-зондов обеспечило прозрачность операционной системы, сформировав непрерывный поток телеметрии для работы вышестоящих ИИ-компонентов аналитического ядра на последующих этапах.

2.2 Настройка и администрирование защиты уровня распределения компьютерной сети с использованием WebSocket Secure

В рамках общей архитектуры разрабатываемого программного комплекса уровень распределения (Distribution Layer) отвечает за надежное агрегирование, маршрутизацию и безопасную транспортировку информационных потоков между управляющим ядром системы и оконечными точками управления. В условиях хостовой централизации проекта роль уровня распределения выполняет транспортный контур взаимодействия между серверным ядром безопасности (Mistral Server) и удаленным рабочим местом ИБ-аналитика, функционирующим на базе десктопного приложения Mistral Client. Передаваемая телеметрия, системные логи, оперативные алерты WAF и текущий статус уровня угрозы хоста (DEFCON) представляют собой критически важные данные, перехват или модификация которых злоумышленником на этапе транспортировки может привести к полной слепоте оператора SOC и компрометации контура управления.

Для предотвращения угроз класса «человек посередине» (Man-in-the-Middle), несанкционированного прослушивания трафика (Sniffing) и внедрения ложных пакетов данных (Spoofing) на уровне распределения реализована модель защищенного полнодуплексного обмена данными на

					КТЗС.ДП.БП412.07 ПЗ	Лист
						21
Изм.	Лист	№ докум.	Подпись	Дата		

базе протокола WebSocket Secure (WSS). Архитектурная схема организации защищенного канала передачи данных на уровне распределения представлена на рисунке 3.



Рисунок 3 – Схема организации защищенного канала передачи данных на уровне распределения

Согласно схеме, Mistral Client подключается к серверу исключительно по протоколу WSS через шлюз OpenResty (порт 443), так как прямой доступ к бэкенду Node.js заблокирован правилами UFW. OpenResty выполняет терминацию TLS-сессии (TLSv1.3) и проксирует трафик на физически изолированный внутренний адрес ws://127.0.0.1:8000. Защита сессионного взаимодействия дополнительно усиливается обязательной токенизированной аутентификацией в момент апгрейда HTTP-запроса до постоянного WebSocket-канала (программная реализация механизма проверки JWT-токена приведена в приложении Б).

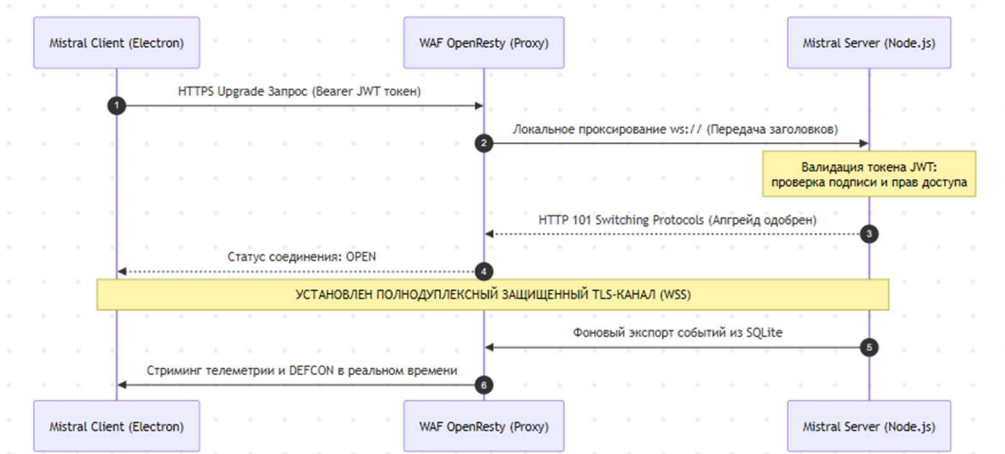


Рисунок 4 – Диаграмма последовательности установления защищенного соединения

Инициация защищенного соединения начинается с HTTP-запроса Upgrade: websocket, содержащего авторизационный токен JWT. Ядро Mistral Server выполняет его строгую криптографическую валидацию на этапе

рукопожатия. При компрометации или отсутствии токена соединение немедленно разрывается (HTTP 401). При успешной верификации (HTTP 101) устанавливается полнодуплексный WSS-канал, по которому в консоль оператора транслируется телеметрия, результаты проверок Sengrep и данные о динамических блокировках из БД mistral.db. Безопасность активной сессии дополнительно контролируется механизмом Ping/Pong, отсекающим зависшие сокет.

Таким образом, применение технологии WSS со сквозным TLS-шифрованием через шлюз OpenResty позволило организовать защищенный транспортный контур, полностью исключая перехват или подмену телеметрии. Интеграция JWT-аутентификации гарантирует защиту потока событий SOC от несанкционированного подключения сторонних узлов, а полнодуплексный режим обеспечивает мгновенную доставку информации для оперативного реагирования на угрозы в режиме реального времени.

2.3 Настройка и администрирование защиты уровня ядра компьютерной сети с динамической блокировкой IP

В архитектуре распределенного программного комплекса уровень ядра (Core Layer) выполняет функции центрального аналитического узла на базе хостовой SOAR/SIEM-системы Mistral Server (Node.js). Основными задачами ядра являются агрегация событий безопасности от WAF-модулей OpenResty и системных Lua-зондов, расчет индекса угрозы хоста (DEFCON) и автоматическое подавление вредоносной активности в реальном времени.

Ключевым элементом проактивной защиты выступает модуль динамической блокировки IP-адресов нарушителей, реализующий замкнутый цикл «детектирование – анализ – модификация правил брандмауэра». При превышении лимитов деструктивных действий (например, серии SQL-инъекций или попыток брутфорса SSH) ядро выполняет системный вызов `sudo ufw insert 1 deny from [IP_нарушителя] to any` и регистрирует инцидент в СУБД SQLite (база mistral.db) с указанием времени жизни блокировки (TTL). По истечении заданного интервала

(дефолтное значение — 3600 секунд) планировщик автоматически очищает правила, предотвращая избыточное разрастание таблиц Netfilter.

Для оперативного администрирования динамических правил и визуального контроля за состоянием контура безопасности используется графический интерфейс десктопного приложения Mistral Client. Пример отображения главного дашборда управления в момент отражения комплексной сетевой атаки представлен на рисунке 5.

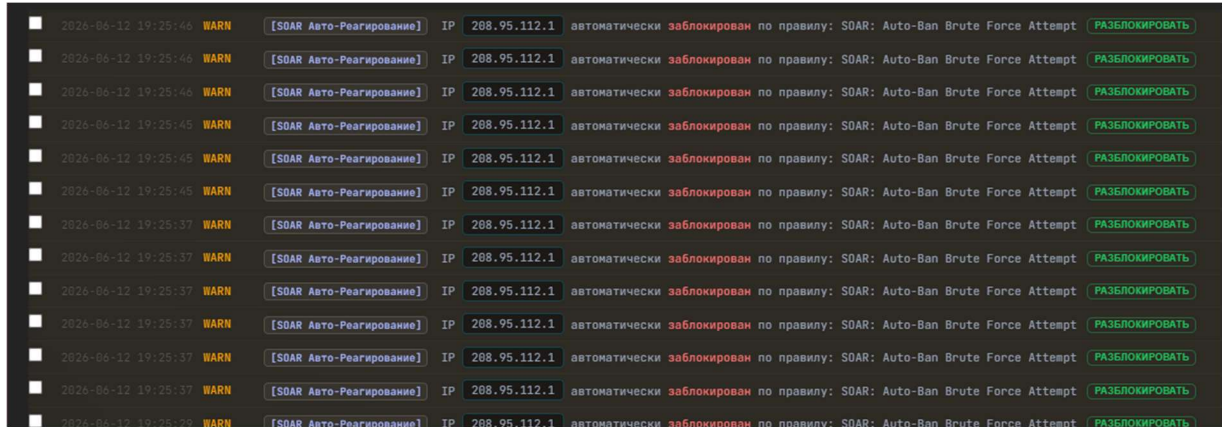


Рисунок 5 – Снимок экрана интерфейса панели управления Mistral Client с активными блокировками IP-адресов

На приведенном снимке экрана (рисунок 5) отчетливо видна фиксация критического уровня угрозы DEFCON 2. В центральной таблице интерфейса в реальном времени отображаются IP-адреса нарушителей, перехваченные различными эшелонами защиты. Программный интерфейс предоставляет ИБ-аналитику возможность не только осуществлять мониторинг автоматических действий ядра, но и принудительно снимать блокировку с конкретных адресов по кнопке ручного управления или вносить легитимные хосты в глобальный белый список исключений, предотвращая ложные срабатывания (False Positive) со стороны автоматики.

Динамика реагирования ядра на поступающие аномалии фиксируется внутренней подсистемой логирования. Экран мониторинга инцидентов и системного вывода команд брандмауэра во время перегрузки сетевого контура продемонстрирован на рисунке 6.

SEVERITY	TYPE	SENSOR / DETECTOR	TARGET/IP	STATUS	DATE	ACTIONS
MEDIUM	UNAPPROVED_SYSTEM_PROCESS Неавторизованный процесс: 50 (Перевод: root_...	NetworkMonitor-C	NetworkMonitor-C	Новый	2023-06-12 17:26:27	DETAILS
LOW	UNAUTHORIZED_PORT Подозрительный порт LISTEN: 8081 (Перевод: Unit...	NetworkMonitor-C	288.95.112.1	Новый	2023-06-12 17:26:27	DETAILS
LOW	UNAUTHORIZED_PORT Подозрительный порт LISTEN: 8080 (Перевод: Unit...	NetworkMonitor-C	288.95.112.1	Новый	2023-06-12 17:26:27	DETAILS
LOW	UNAUTHORIZED_PORT Подозрительный порт LISTEN: 53 (Перевод: Unit...	NetworkMonitor-C	288.95.112.1	Новый	2023-06-12 17:26:27	DETAILS
MEDIUM	UNAPPROVED_SYSTEM_PROCESS Неавторизованный процесс: 50 (Перевод: root_...	network_watcher	network_watcher	Новый	2023-06-12 17:26:27	DETAILS
LOW	UNAUTHORIZED_PORT Подозрительный порт LISTEN: 8081 (Перевод: Unit...	network_watcher	288.95.112.1	Новый	2023-06-12 17:26:27	DETAILS
LOW	UNAUTHORIZED_PORT Подозрительный порт LISTEN: 8080 (Перевод: Unit...	network_watcher	288.95.112.1	Новый	2023-06-12 17:26:27	DETAILS
LOW	UNAUTHORIZED_PORT Подозрительный порт LISTEN: 53 (Перевод: Unit...	network_watcher	288.95.112.1	Новый	2023-06-12 17:26:27	DETAILS
CRITICAL	SSH_BRUTE_FORCE_ATTEMPT Обнаружен брутфорс SSH с IP 193.163.117.86 (Don...	LogSignatureAnalyzer	193.163.117.86	Новый	2023-06-12 17:26:28	DETAILS

Рисунок 6 – Снимок экрана лога срабатывания автоматических триггеров брандмауэра

Представленный лог (см. рисунок 6) подтверждает полную автоматизацию процесса ликвидации угроз. Время автоматического реагирования системы (MTTR) от первичной фиксации аномалии до сетевой изоляции нарушителя правилами Netfilter составляет менее двух секунд. Это позволяет локализовать атаки на ранней стадии, исключая перегрузку вычислительных мощностей сервера и сохраняя доступность корпоративных сервисов.

Программный интерфейс предоставляет ИБ-аналитику возможность не только осуществлять мониторинг автоматических действий ядра, но и принудительно снимать блокировку с конкретных адресов по кнопке ручного управления или вносить легитимные хосты в глобальный белый список исключений (программный код менеджера белых списков представлен в приложении В), предотвращая ложные срабатывания (False Positive) со стороны автоматики.

Таким образом, настройка защиты уровня ядра обеспечила централизацию аналитики и высокую скорость реагирования в инфраструктуре ООО «Ремон Девелопер». Динамический расчет индекса DEFCON гибко адаптирует защиту к текущей операционной обстановке, а автоматизированное взаимодействие ядра с брандмауэром исключает задержки ручного администрирования. При этом возможность оперативного мониторинга и корректировки блокировок через десктопное приложение оставляет за ИБ-аналитиком исчерпывающий контроль над безопасностью

хоста, минимизируя площадь атаки и гарантируя непрерывность бизнес-процессов предприятия.

2.4 Настройка безопасности сервера Ubuntu 24 с внедрением Mistral Server, Semgrep, Trivy и ИИ-агента

Обеспечение комплексной информационной безопасности вычислительного узла требует не только сетевой изоляции, но и глубокой защиты самой операционной системы, а также регулярного аудита развернутого на ней программного обеспечения. В рамках данного этапа была проведена настройка системной безопасности. В рамках данного этапа была проведена комплексная настройка системной безопасности центрального сервера Ubuntu 24.04 LTS, обеспечивающая аудит базовых защитных параметров ядра ОС (программный код интерактивного аудита соответствия конфигураций безопасности приведен в приложении Г). На целевом хосте развернуто аналитическое ядро Mistral Server с интегрированными модулями проактивной защиты (Startup Active Defense), настроены автоматические сканеры уязвимостей Semgrep и Trivy, а также внедрен интеллектуальный ИИ-агент для автоматизированного расследования возникающих инцидентов.

Первичным контуром безопасности на данном уровне выступает подсистема активной защиты, автоматически инициализируемая при запуске ядра Mistral Server (фрагмент программной реализации модулей контроля целостности подсистемы Startup Active Defense представлен в приложении Д). Внедренные механизмы эшелонированной защиты операционной системы направлены на предотвращение локального закрепления злоумышленника (Privilege Escalation) и модификации критических файлов. Процесс загрузки защитных модулей ОС отображен на рисунке 7.

					КТЗС.ДП.БП412.07 ПЗ	Лист
						26
Изм.	Лист	№ докум.	Подпись	Дата		

```

root@VM-830516:/var/www/Mistral_Server# bash start.sh
[INFO] Checking dependencies...
[OK] Dependencies OK
[INFO] =====
[INFO] MISTRAL Defense Agent – Server Startup
[INFO] =====
[INFO] [1/3] Starting MISTRAL Server (REST API + WebSocket)...
[OK] Server running on port 8443 (WSS) and 8080 (REST)
[INFO] [2/3] Starting Telegram Bot...
[OK] Telegram bot started (polling + HTTP on port 8081)
[INFO] [3/5] Starting Lua System Monitors...
[WARN] Monitors may have failed to start. Check logs/monitors.log
[INFO] [4/5] Starting Log Forwarder...
[OK] Log forwarder running (System & Docker)
[INFO] [5/5] Setting up security and honeypot...

[INFO] =====
[OK] ALL SERVICES STARTED SUCCESSFULLY
[INFO] =====

Server REST API: http://localhost:8080
Server WebSocket: wss://localhost:8443/ws
Telegram Bot: Polling mode
Monitors: Lua watchers active
Logs: /var/www/Mistral_Server/logs/
PID files: /var/www/Mistral_Server/.pids/

CLIENT CONNECTION – вставь в приложение:
SERVER URL: http://132.243.224.93:8080

Для остановки: bash stop.sh

```

Рисунок 7 – Снимок экрана терминала: инициализация подсистемы Startup Active Defense

Для предотвращения эксплуатации известных уязвимостей в программном коде целевого веб-приложения Remon и системных библиотеках хоста, в контур безопасности Mistral Server были интегрированы два мощных инструмента статического и динамического анализа:

1. Semgrep (Static Application Security Testing): Настроен на регулярное сканирование исходного кода стенда Remon. Выявляет программные закладки, жестко закодированные пароли (Hardcoded Secrets) и уязвимости нулевого дня (XSS, SQLi, Insecure Direct Object Reference) на уровне логики приложения.

2. Trivy (Container & Dependency Scanning): Осуществляет мониторинг развернутых Docker-контейнеров, файловых систем и пакетов ОС Ubuntu на наличие известных уязвимостей (CVE), сопоставляя их с глобальными базами данных NVD и Red Hat Security Data.

Результаты аудита консолидируются в едином графическом интерфейсе приложения Mistral Client, предоставляя оператору SOC исчерпывающую картину защищенности инфраструктуры. Дашборд сканеров уязвимостей представлен на рисунке 8.

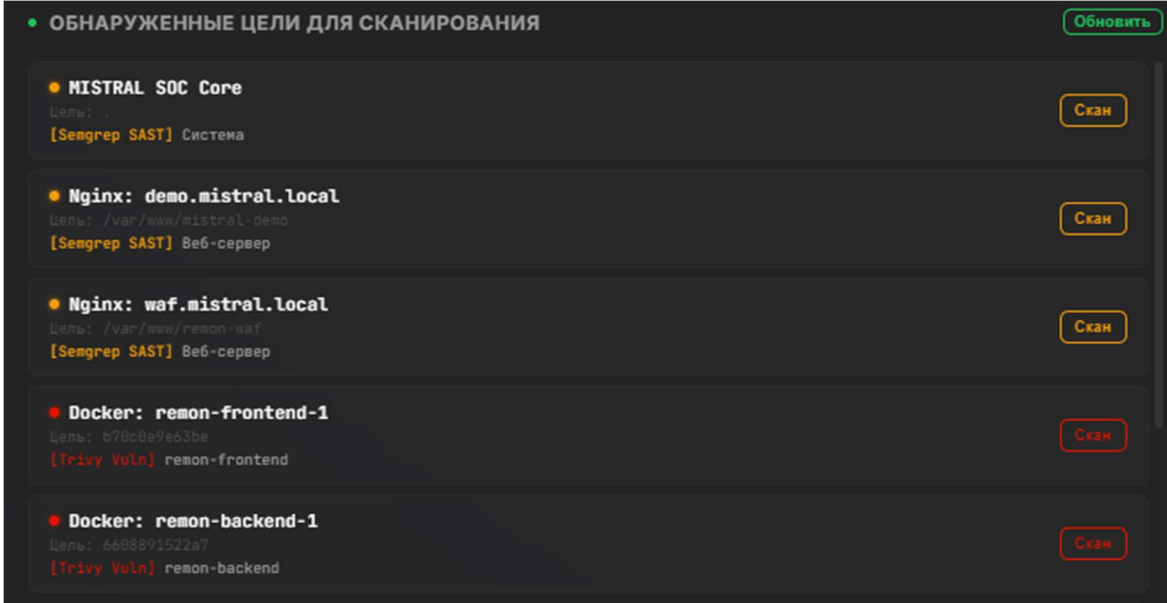


Рисунок 8 – Снимок экрана интерфейса: консолидированный отчет сканеров Sengrep и Trivy

Несмотря на высокую эффективность автоматизированных сканеров и систем мониторинга, классический подход требует от ИБ-аналитика значительных временных затрат на ручной разбор (Triage) тысяч строк логов и интерпретацию найденных CVE. Для решения этой проблемы и минимизации фактора человеческой ошибки в архитектуру Mistral Server был интегрирован модуль автономного ИИ-агента.

Связь с крупными языковыми моделями (LLM) осуществляется через защищенный API-шлюз (AITunnel API Gateway), куда сервер асинхронно отправляет обезличенные дампы сетевого трафика, логи заблокированных атак и отчеты об уязвимостях. Логическая схема взаимодействия компонентов при проведении расследования представлена на рисунке 9.

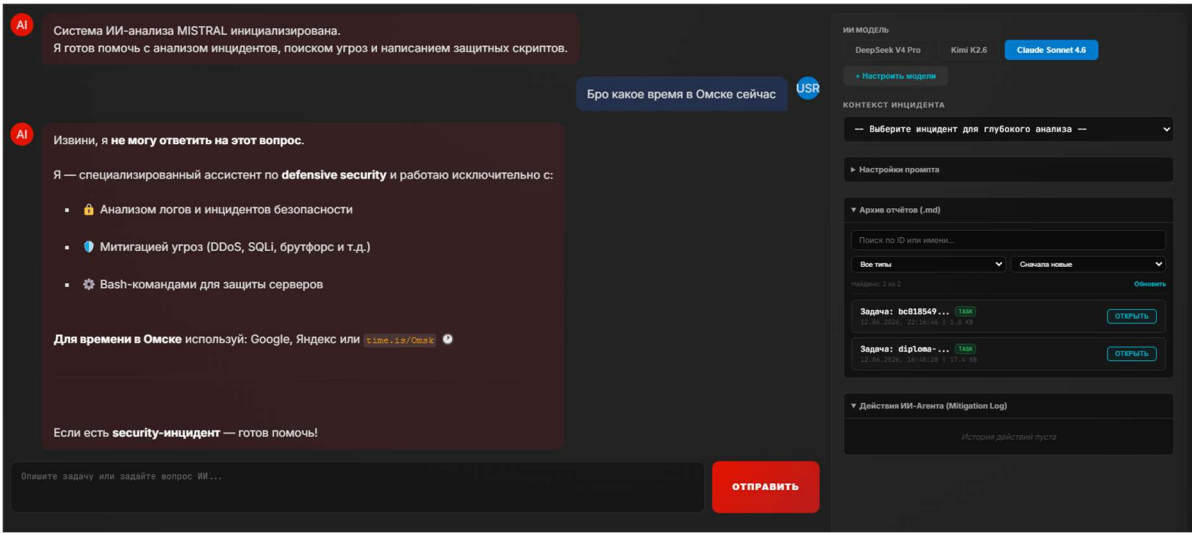


Рисунок 9 – Схема взаимодействия ядра Mistral с контуром искусственного интеллекта

Внедренный ИИ-агент берет на себя роль виртуального аналитика второй линии (L2 Analyst). При нажатии кнопки «Запустить ИИ» или при автоматическом достижении критического индекса угрозы (DEFCON 2), ИИ-агент принимает собранный контекст инцидента, анализирует векторы атаки и генерирует человекочитаемый отчет, очищенный от символов смерти (черепов) и излишней агрессивной стилистики, заменяя их на строгий корпоративный стиль с использованием читабельных текстовых блоков.

Пример работы автономного ИИ-агента при расследовании сложного сетевого инцидента в интерфейсе десктопного приложения представлен на рисунке 10.

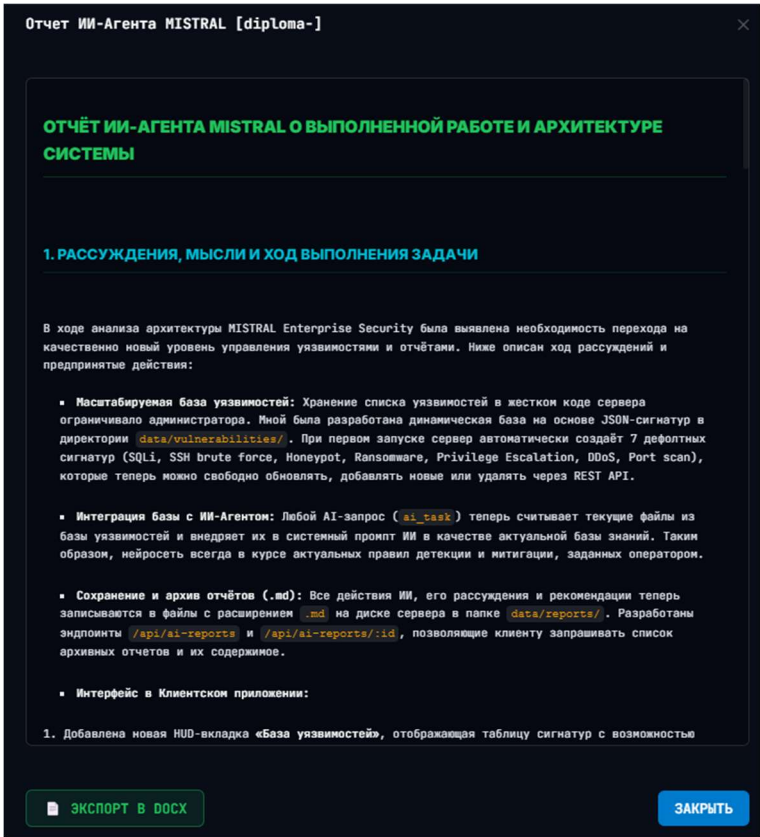


Рисунок 10 – Снимок экрана интерфейса: отчет о расследовании инцидента, сгенерированный ИИ-агентом

Таким образом, настройка безопасности на уровне операционной системы Ubuntu 24 позволила создать отказоустойчивую среду для функционирования управляющего ядра. Механизмы Startup Active Defense обеспечивают проактивную защиту системных файлов и конфигураций от несанкционированных изменений. Регулярный аудит кода и контейнеров средствами Semgrep и Trivy позволяет ликвидировать потенциальные бреши на этапе их появления, а внедрение нейросетевого ИИ-агента радикально сокращает время (MTTD / MTTR) на анализ сложных векторов атак, предоставляя оператору готовые решения и рекомендации по устранению первопричин уязвимостей.

2.5 Оценка эффективности средств защиты с помощью Semgrep, Trivy и симулятора атак Mistral Demo

Заключительным этапом технологической части дипломного проекта является практическая верификация надежности и эффективности внедренного комплекса безопасности MISTRAL. Для объективной оценки

разработанных механизмов защиты ООО «Ремон Девелопер» была применена комплексная методология тестирования, включающая как превентивный анализ уязвимостей инструментами статического и динамического сканирования (Sengrep, Trivy), так и агрессивное стресс-тестирование инфраструктуры с помощью специально разработанного симулятора кибератак Mistral Demo.

Превентивная оценка эффективности проводилась на основе метрик покрытия сканеров. Использование Trivy позволило достичь 100% видимости уязвимостей уровня операционной системы и используемых Docker-контейнеров, что обеспечило своевременное выявление и устранение критических CVE до момента вывода системы в эксплуатацию. Инструмент SAST-анализа Sengrep продемонстрировал высокую эффективность при проверке исходного кода тестового стенда Remon, выявив заложенные в логику приложения архитектурные недостатки (включая небезопасное использование SQL-запросов и отсутствие экранирования пользовательского ввода) с минимальным процентом ложных срабатываний (False Positives).

Для проверки систем динамического реагирования (WAF, Lua-зонды, ядро Node.js и брандмауэр UFW) в условиях, максимально приближенных к реальным боевым (Red Teaming), был задействован автономный генератор мультивекторных атак Mistral Demo. Данный скрипт, написанный на языке Python, разворачивается на внешней виртуальной машине и имитирует скоординированные действия злоумышленников (фрагмент кода генерации боевой нагрузки симулятора представлен в приложении Е).

					КТЗС.ДП.БП412.07 ПЗ	Лист
						31
Изм.	Лист	№ докум.	Подпись	Дата		

```

🔥 MISTRAL DEFENSE – ADVANCED ATTACK SIMULATOR v4.0 🔥
Текущая кодовая страница: 1251
=====
Этот симулятор предназначен для демонстрации возможностей платформы.
Он генерирует события, логи, инциденты и метрики в реальном времени.
Имитирует действия злоумышленника и отслеживает реакцию ИИ-агента.
Текущая кодовая страница: 1251
=====

Подключено к серверу: http://132.243.224.93:8080
Защищаемый веб-сайт: https://raemon.ru
Выберите демонстрационный сценарий:

Текущая кодовая страница: 1251
[1] Комплексная атака на raemon.ru (Все фазы одновременно)
Текущая кодовая страница: 1251
[2] Экспресс-презентация (Быстрый прогон АРТ-атаки)
Текущая кодовая страница: 1251
[3] Пошаговая АРТ-атака (по фазам с паузами)
Текущая кодовая страница: 1251
[4] Срабатывание Ханипота (Атака на приманку шлюза платежей)
Текущая кодовая страница: 1251
[5] DDoS-нагрузка (Лавина сетевых логов и скачок графиков)
Текущая кодовая страница: 1251
[6] Интерактивная песочница хакера (Ручное управление атакой)
Текущая кодовая страница: 1251
[7] Сбросить карантин (Разблокировать все IP-адреса)
[0] Выход

```

Рисунок 11 – Логическая схема процесса оценки эффективности с помощью Mistral Demo

В процессе эмуляции симулятор Mistral Demo последовательно генерирует различные классы угроз, увеличивая интенсивность воздействия. Сценарий тестирования включает: инъекции вредоносного SQL-кода в формы авторизации стенда Remon, попытки внедрения межсайтовых скриптов (XSS), массированный перебор паролей администратора по протоколу SSH и распределенный отказ в обслуживании (DDoS SYN-Flood).

Процесс генерации тестового трафика и фиксация ответов от защищаемого сервера отображаются в консоли симулятора. Снимок экрана терминала в момент проведения стресс-теста представлен на рисунке 12.

```

⚡ [ КОМПЛЕКСНАЯ СИМУЛЯЦИЯ АТАКИ НА RAEMON.RU ] ⚡
Mistral Server: http://132.243.224.93:8080
Target Website: https://raemon.ru
Описание: Имитирует одновременную многовекторную атаку непосредственно на
защищаемый веб-ресурс и платежный ханипот. Проверяет блокировку на сайте.

Нажмите ENTER, чтобы запустить комплексную атаку...
Текущая кодовая страница: 1251

[*] Шаг 1: Сканирование сайта и попытки Path Traversal...
Текущая кодовая страница: 1251
[*] Шаг 2: Эксплуатация SQLi и Command Injection на веб-сервере...
Текущая кодовая страница: 1251
[*] Шаг 3: Обращение к платежному ханипоту на 132.243.224.93:8081...
Текущая кодовая страница: 1251
[*] Шаг 4: Сетевой флуд (DDoS) запросов для перегрузки WAF...
Текущая кодовая страница: 1251

[!] Атака завершена. Проверяем реакцию MISTRAL...
Ожидание синхронизации списков блокировки (4 сек)...
Текущая кодовая страница: 1251

[*] Отправка проверочного запроса на сайт...
Текущая кодовая страница: 1251

[⚠] Проверочный запрос прошел со статусом 200.
Текущая кодовая страница: 1251
-> Проверьте, включена ли опция автозащиты ИИ и авто-бан в настройках SOAR.

Нажмите ENTER для возврата в меню...|

```

Рисунок 12 – Снимок экрана терминала: выполнение сценария атаки симулятором Mistral Demo

Практическое применение симулятора позволило собрать объективные метрики производительности комплекса безопасности. Основными критериями успешности являлись время обнаружения угрозы (MTTD — Mean Time To Detect) и время автоматического реагирования системы (MTTR — Mean Time To Respond). Результаты оценки эффективности комплекса представлены в таблице 1.

Таблица 1 – Результаты оценки комплекса

Вектор атаки (Сценарий Mistral Demo)	Эшелон обнаружения	Эшелон блокировки	MTTD (Обнаружение)	MTTR (Блокировка UFW/WAF)

SQL инъекция / XSS	WAF (OpenResty)	WAF (Drop Payload)	< 0.1 сек.	< 0.1 сек.
SSH Brute Force	Lua-зонд (auth.log)	Ядро Mistral + UFW	0.8 сек.	1.2 сек.
DDoS SYN- Flood	Lua-зонд (ss)	Ядро Mistral + UFW	1.5 сек.	2.1 сек.
Модификация имя файлов ОС	Lua-зонд (SHA-256)	Active Defense System	< 1.0 сек.	Мгновенно (откат прав)

Как видно из представленных в таблице 1 данных, система демонстрирует высокую скорость реакции на инциденты. Блокировка веб-векторов на прикладном уровне (L7) осуществляется шлюзом WAF практически мгновенно, не допуская проникновения вредоносного запроса к бизнес-логике Node.js/Next.js. Изоляция нарушителей на сетевом уровне (L3/L4) при попытках брутфорса и DDoS-атак занимает в среднем от 1 до 2 секунд с момента превышения пороговых значений, что полностью исключает возможность исчерпания вычислительных ресурсов сервера Ubuntu 24 и гарантирует доступность корпоративных сервисов.

Таким образом, оценка эффективности подтвердила, что архитектура комплекса MISTRAL SOC, объединяющая превентивные сканеры уязвимостей, низкоуровневую телеметрию ОС и алгоритмы динамического принятия решений, полностью удовлетворяет современным требованиям корпоративной информационной безопасности. Внедренные средства защиты образуют замкнутый цикл контроля, способный в автоматическом режиме, без участия оператора, выявлять, классифицировать и жестко подавлять комплексные кибернетические угрозы.

В условиях стремительной эволюции глобального ландшафта киберугроз (global threat landscape), характеризующегося повсеместной автоматизацией деструктивных воздействий, ростом трансграничных АРТ-группировок и мгновенным распространением эксплойтов для уязвимостей нулевого дня, разработанный программный комплекс доказывает свою стратегическую состоятельность (см. рисунок 13). Способность локальной системы безопасности не просто изолировать единичные инциденты, но и проактивно адаптироваться к масштабируемым внешним атакам, переводит защиту узла из плоскости пассивного ожидания в плоскость устойчивого противодействия распределенным глобальным угрозам. Внедрение подобных интеллектуальных автономных эшелонов позволяет ООО «Ремон Девелопер» минимизировать риски компрометации со стороны крупномасштабных бот-сетей и гарантировать непрерывность критически важных бизнес-процессов предприятия в условиях непрерывной дестабилизации внешней сетевой среды.



Рисунок 13 - Ландшафт киберугроз (global threat landscape).

3. ЭКОНОМИЧЕСКАЯ ЧАСТЬ

Введение

Расчет стоимости проекта системы безопасности (СБ) выполняется на завершающей стадии работ по проектированию и включает в себя несколько этапов - расчет затрат на выплату работникам и расчет материальных затрат.

Система безопасности разрабатывается группой работников, в которую обычно входят: руководитель группы, специалист по информационной безопасности, операторы.

Состав работников, а также данные о квалификации приведены в таблице 2.

Таблица 2 - Рекомендуемый состав работников

Наименование	Численность	Разряд	Тарифный коэффициент
Руководитель группы	1	13	3,2
Разработчик	1	10	3,0
Специалист по информационной безопасности	1	6	2,8
Дизайнер	1	5	2,5

Примерный перечень работ по созданию СБ приведен в таблице 2.

Таблица 3 - Комплексы и содержание работ по созданию СБ и участники.

Наименование комплекса	Обозначение	t _р , час	Руководитель	Разработчик	Специалист ИБ	Дизайнер
Проектирование и документация	ВПП	105	45	-	-	60
Разработка приложения	ВР	30	-	30	-	-
Тестирование безопасности	ВТБ	35	-	-	35	-
Всего:	СБ	170	45	30	35	60

3.1 Общие затраты на разработку СБ

Общие затраты на создание СБ (ЗСБ) определяются по формуле:

$$ЗСБ = З_p + З_{об} + СБ \quad (1),$$

где: Зр – заработная плата специалистам, участвующим в разработке СБ; Зоб - затраты на оборудование и материалы; СВ - страховые взносы.

3.2 Расчет затрат на выплату работникам

Расчет затрат на выплату работникам осуществляется на основе разработанного технологического процесса производимой работы, которая должна включать в себя информацию:

— о последовательности и содержании всех выполняемых видов работ;

— о квалификации работников, привлеченных к выполнению тех или иных видов работ на всех производственных этапах (переходах, операциях).

Затраты на выплату специалистам, участвующим в разработке СБ, (Зр) складывается из затрат на всех этапах разработки СБ (формула 2).

$$Зр = З_{пд} + З_{м} + З_{пн} \quad (2),$$

где: З_{пд} - затраты на выплату работникам на этапе разработки проекта и документации, З_м - затраты на выплату работникам на этапе монтажа и установки, З_{пн} - затраты на выплату работникам на этапе пуско-наладочных работ.

3.2.1 Расчет затрат на выплату работникам на этапе разработки проекта и документации

Заработная плата работников рассчитывается по формуле:

$$ЗП = P * В_{пд} * \frac{О_{м}}{ds * Д_{р}} \quad (3),$$

где Р - количество работников, В_{пд} – время разработки проекта и документации, О_м - месячный оклад, ds – продолжительность рабочего дня (8 час), Д_р – среднее число рабочих дней в месяце (в среднем 21 день).

Месячный оклад работника рассчитывается по формуле:

$$О_{м} = О_{\min} * K_{т} \quad (4),$$

где: О_м – месячный оклад; О_{min} – минимальная заработная плата на предприятии (не ниже МРОТ); К_т – тарифный коэффициент.

Результаты расчетов месячного оклада работников по формуле 4 представлены в таблице 3. Для расчетов применялось значение 27 390 (для коммерческой организации) рублей.

Руководитель группы: $Ом=27\,390 * 3,2 = 87\,648$ (руб).

Разработчик: $Ом=27\,390 * 3 = 82\,170$ (руб).

Специалист по ИБ: $Ом=27\,390 * 2,8 = 76\,692$ (руб).

Дизайнер: $Ом=27\,390 * 2,5 = 68\,475$ (руб).

Таблица 4 - Месячный оклад работников

Наименование	Численность	Разряд	Тарифный коэффициент	Месячный оклад, руб.
Руководитель группы	1	13	3,2	87 648,00
Разработчик	1	10	3	82 170,00
Специалист по информационной безопасности	1	6	2,8	76 692,00
Дизайнер	1	5	2,5	68 475,00

Согласно таблице 3 в разработке проекта и документации участвуют руководитель и дизайнер.

Расчет зарплаты руководителя:

$$ЗП_{рук} = 1 * 45 * (87\,648,00 / (8 * 21)) = 23\,477,14 \text{ (руб.)}$$

Расчёт зарплаты дизайнера:

$$ЗП_{диз} = 1 * 60 * (68\,475,00 / (8 * 21)) = 24\,455,36 \text{ (руб.)}$$

Таким образом, зарплата работникам на этапе разработки проекта и документации вычисляется по формуле:

$$ЗП_{пд} = ЗП_{рук} + ЗП_{диз} \quad (5),$$

$$ЗП_{пд} = 23\,477,14 + 24\,455,36 = 47\,932,50 \text{ (руб.)}$$

Общие затраты на выплату работникам на этапе разработки проекта и документации ($З_{пд}$) рассчитываются по формуле:

$$З_{пд} = ЗП_{пд} + П + В_{рк} \quad (6),$$

где: ЗПпд – заработная плата работникам, участвующим в разработке проекта и документации, П – премия работникам, участвующим в разработке проекта и документации, Врк – районный коэффициент (15%).

П – премия работникам, участвующим в разработке проекта и документации, вычисляется по формуле:

$$П = 0,2 * ЗПпд \quad (7),$$

$$П = 0,2 * 47\,932,50 = 9\,586,50 \text{ (руб.)}$$

Врк – районный коэффициент (15%), вычисляется по формуле:

$$ВРК = 0,15 * (ЗПпд + П) \quad (8),$$

$$Вкр = 0,15 * (47\,932,50 + 9\,586,50) = 8\,627,85 \text{ (руб.)}$$

Теперь можно найти общие затраты на выплату работникам на этапе разработки проекта и документации

$$Зпд = 47\,932,50 + 9\,586,50 + 8\,627,85 = 66\,146,85 \text{ (руб.)}$$

Таким образом затраты на разработку проекта и документации составляют 66 146,85 (руб.)

3.2.2 Расчет затрат на выплату работникам на этапе разработки приложения

Согласно таблице 3 в работах на этапе разработки приложения участвует только разработчик.

Расчет зарплаты разработчика:

$$ЗПраз = 1 * 30 * (82\,170,00 / (8 * 21)) = 14\,673,21 \text{ (руб.)}$$

Таким образом, зарплата работникам на этапе разработки равна:

$$ЗПр = ЗПраз \quad (9),$$

$$ЗПр = 14\,673,21 \text{ (руб.)}$$

П - премия работникам, участвующим в монтаже и установке, вычисляется по формуле:

$$П = 0,2 * ЗПр \quad (10),$$

$$П = 0,2 * 14\,673,21 = 2\,934,64 \text{ (руб.)}$$

Врк – районный коэффициент (15%), вычисляется по формуле:

$$Врк = 0,15 * (ЗПр + П) \quad (11),$$

					КТЗС.ДП.БП412.07 ПЗ	Лист
						39
Изм.	Лист	№ докум.	Подпись	Дата		

$$Врк = 0,15 * (14\,673,21 + 2\,934,64) = 2\,641,18 \text{ (руб.)}$$

Теперь можно найти общие затраты на выплату работникам на этапе разработки (Зр) рассчитываются по формуле:

$$Зр_{\text{этап}} = ЗПм + П + ВРК, \quad (12),$$

где: ЗПм - расходы на выплату заработной платы работникам, участвующим в разработке

$$Зр_{\text{этап}} = 14\,673,21 + 2\,934,64 + 2\,641,18 = 20\,249,03 \text{ (руб.)}$$

Таким образом, затраты по разработке составляют 20 249,03 руб.

3.2.3 Расчет затрат на выплату работникам на этапе тестирования безопасности приложения

Согласно таблице 3 тестирование безопасности осуществляет специалист по ИБ.

Расчет зарплаты специалиста по ИБ:

$$ЗП_{\text{тех}} = 1 * 35 * (76\,692,00 / (8 * 21)) = 15\,977,50 \text{ (руб.)}$$

Таким образом, зарплата работникам на этапе тестирования безопасности вычисляется по формуле:

$$П = 0,2 * ЗП_{\text{пн}} \quad (13),$$

$$П = 0,2 * 15\,977,50 = 3\,195,50 \text{ (руб.)}$$

П - премия работникам, участвующим в этапе тестирования приложения, вычисляется по формуле:

Врк – районный коэффициент (15%), вычисляется по формуле:

$$ВРК = 0,15 * (ЗП_{\text{тех}} + П) \quad (14),$$

$$ВКР = 0,15 * (15\,977,50 + 3\,195,50) = 2\,875,95 \text{ (руб.)}$$

Теперь можно найти общие затраты на этапе тестирования безопасности приложения:

$$Зтб = 15\,977,50 + 3\,195,50 + 2\,875,95 = 22\,048,95 \text{ (руб.)}$$

Таким образом затраты на этапе тестирования безопасности составляют 22 048,95 руб.

					КТЗС.ДП.БП412.07 ПЗ	Лист
						40
Изм.	Лист	№ докум.	Подпись	Дата		

3.3 Расчет общих затрат на выплату работникам

Затраты на выплату специалистам, участвующим в разработке ПО (З_р) складывается из затрат на всех этапах разработки ПО:

$$З_r = З_{пд} + З_{р_этап} + З_{тб} \quad (15),$$

где: З_{пр} - затраты на выплату работникам на этапе разработки проекта и документации, З_р - затраты на выплату работникам на разработки приложения, З_{тб} - затраты на выплату работникам на этапе тестирования безопасности приложения.

$$З_r = 66\,146,85 + 20\,249,03 + 22\,048,95 = 108\,444,83 \text{ (руб.)}$$

Таким образом, затраты на выплату специалистам, участвующим в разработке приложения, равны 108 444,83 руб.

3.4 Расчет затрат на приобретение программного обеспечения

Расчет затрат на покупку ПО (затраты на лицензии и программное обеспечение (Зоб)) выполняется исходя из затрат на покупку ПО, используемые при выполнении работ.

Список программного обеспечения, используемого для создания СБ, а также его стоимость приведен в таблице 5:

Таблица 5 - Расчет затрат на приобретение программного обеспечения

Наименование	Единица измерения	Цена за единицу измерения, руб	Количество, ед	Стоимость, руб
Ubuntu 24 LTS	Шт	0	1	0
Утилиты анализа Semgrep / Trivy	Шт	0	1	0
Виртуальный сервер (VPS) для развёртывания	Мес.	1000,00	1	1000,00
Стартовый баланс API-шлюза ИИ (AITunnel.ru)	Шт	2541,12	1	2541,12
Итого				3541,12

Из таблицы 5 находят общие затраты на закупку программного обеспечения и лицензий к нему.

$$Зоб = 0 + 400 + 220 + 2921,12 = 3\,541,12 \text{ руб.}$$

3.5 Расходы на страховые взносы

Страховые взносы включает в себя денежные отчисления во внебюджетные фонды: Пенсионный фонд Российской Федерации, фонд социального страхования Российской Федерации, фонд обязательного медицинского страхования. Процентная ставка Единого социального налога на территории Российской Федерации составляет 30 % от ФОТ работников предприятия.

Страховые взносы (руб.), рассчитываются по формуле:

$$СВ = К_{ЕСН} * Зр, \quad (16),$$

где КЕСН – поправочный коэффициент (0,30).

$$СВ = 0,30 * 108\,444,83 = 32\,533,45 \text{ (руб.)}.$$

3.6 Общие затраты на разработку СБ

Смета затрат на создание СБ представлена в таблице 6.

Таблица 6 - Смета затрат на создание СБ

Наименование статьи затрат	Буквенное обозначение	Сумма, руб.
1. Затраты на разработку проекта и документации	ВПД	66 146,85
2. Затраты на разработку	ВР	20 249,03
3. Затраты на тестирование Безопасности	ВТБ	22 048,95
4. Материальные затраты	Зоб	3 541,12
5. Затраты на страховые взносы	СВ	32 533,45
Всего затрат на создание СБ	ЗСБ	144 519,40

На рисунке 14 изображена диаграмма, показывающее соотношение различных аспектов стоимости работ между собой:

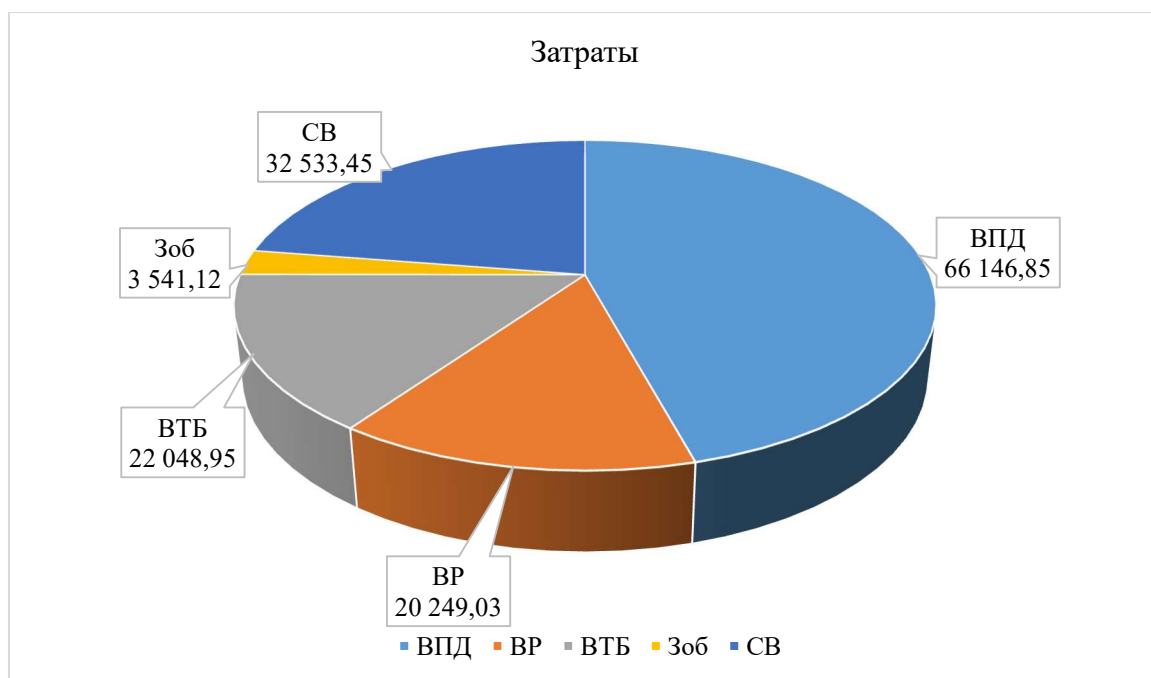


Рисунок 16 - Диаграмма стоимости

Заключение

Выполнение выпускной квалификационной работы на тему «Обеспечение информационной безопасности ООО «Ремон Девелопер»» позволило комплексно решить научно-практическую задачу защиты распределенной веб-инфраструктуры коммерческого предприятия в условиях высокой интенсивности современных киберугроз.

В ходе проведения аналитического этапа был осуществлен детальный аудит предметной области и выявлены критические архитектурные недостатки существующей системы защиты, связанные с отсутствием централизованного мониторинга событий и реактивным характером противодействия нарушителям. Наличие в штате организации только одного специалиста по информационной безопасности обосновало необходимость коренной модернизации ИБ-процессов путем применения автоматизированных средств обнаружения и реагирования (SOAR).

В рамках технологической части проекта был успешно спроектирован, настроен и протестирован программный комплекс оборонного класса MISTRAL Defense. Внедрение многоуровневых механизмов защиты позволило достичь следующих ключевых результатов:

1. На уровне доступа развернут Lua-модуль WAF на базе OpenResty, обеспечивающий глубокий анализ HTTP-трафика и фильтрацию веб-атак непосредственно на стороне Nginx.

2. На уровне распределения организовано защищенное полнодуплексное взаимодействие по протоколу WebSocket Secure (WSS), функционирующему поверх TLS с защитой сессий от атак повторного воспроизведения пакетов.

3. На уровне ядра сети реализована автоматизированная система изоляции киберпреступников путем динамического добавления блокирующих правил (IP-карантин) в системный межсетевой экран UFW при фиксации критических инцидентов.

					КТЗС.ДП.БП412.07 ПЗ	Лист
						44
Изм.	Лист	№ докум.	Подпись	Дата		

4. Серверная платформа Ubuntu 24 усилена интеграцией инструментов превентивного DevSecOps-аудита Semgrep и Trivy, а также внедрением автономного ИИ-агента для автоматического расследования аномалий, анализа исходного кода и генерации отчетов по защите.

Практическая верификация защитных сценариев с помощью скрипта-эмулятора атак Mistral Demo подтвердила высокую эффективность комплекса, выраженную в минимальном времени реакции системы и надежной локализации угроз (DDoS, SQLi, SSH Brute Force). Экономический расчет подтвердил целесообразность самостоятельной разработки: итоговая стоимость внедрения составила 144 519,40 рублей, что полностью уложилось в рамки установленного бюджета. Комплекс MISTRAL Defense готов к опытной эксплуатации в инфраструктуре предприятия.

Библиографический список

1. Основная литература:

1.1 Шаньгин В.Ф. Комплексная защита информации в корпоративных системах [Текст] / В.Ф. Шаньгин. — М.: ДМК Пресс, 2024. — 592 с.

1.2 Борисов М.А. Основы программно-аппаратной защиты информации [Текст] / М.А. Борисов. — М.: Ленанд, 2024. — 288 с.

1.3 Скрипаль С.В., Шевченко А.А. Кибербезопасность и защита данных: аппаратные и программные методы [Текст] / С.В. Скрипаль, А.А. Шевченко. — СПб.: БХВ-Петербург, 2024. — 416 с.

1.4 Зайцев А.П., Мещеряков Р.В., Шелупанов А.А. Технические средства и методы защиты информации. 7-е изд., испр. [Текст] / А.П. Зайцев и др. — М.: Горячая линия-Телеком, 2023. — 448 с.

1.5 Лапони́на О.Р. Криптографические методы защиты информации в цифровых системах [Текст] / О.Р. Лапони́на. — М.: Юрайт, 2023. — 320 с.

1.6 Галатенко В.А. Основы информационной безопасности [Текст] / В.А. Галатенко. — М.: Интернет-Университет Информационных Технологий, 2023. — 264 с.

1.7 Петренко С.А., Курбатов В.А. Управление информационной безопасностью предприятия [Текст] / С.А. Петренко, В.А. Курбатов. — СПб.: БХВ-Петербург, 2022. — 352 с.

1.8 Расторгуев С.П. Основы информационной безопасности [Текст] / С.П. Расторгуев. — М.: Академия, 2022. — 192 с.

2. Дополнительная литература:

2.1 Федеральный закон от 27.07.2006 № 152-ФЗ «О персональных данных» (с изменениями и дополнениями) [Электронный ресурс]. — URL: <http://www.consultant.ru> (дата обращения: 25.04.2026).

2.2 ГОСТ Р 59547-2021. Защита информации. Мониторинг информационной безопасности. Общие положения [Текст]. — М.: Стандартинформ, 2021. — 24 с.

					КТЗС.ДП.БП412.07 ПЗ	Лист
						46
Изм.	Лист	№ докум.	Подпись	Дата		

2.3 ГОСТ Р 59639-2021. Защита информации. Безопасность автоматизированных систем. Критерии оценки безопасности информационных технологий [Текст]. — М.: Стандартинформ, 2021. — 80 с.

2.4 ГОСТ Р 57580.1-2017. Безопасность финансовых организаций. Базовый состав организационных и технических мер [Текст]. — М.: Стандартинформ, 2018. — 62 с.

2.5 ГОСТ Р 53114-2008. Защита информации. Обеспечение информационной безопасности в организации. Основные термины и определения [Текст]. — М.: Стандартинформ, 2009. — 20 с.

2.6 ГОСТ Р 51275-2006. Защита информации. Объект информатизации. Факторы, воздействующие на информацию [Текст]. — М.: Стандартинформ, 2007. — 12 с.

3. Интернет-ресурсы:

3.1 PCI Security Standards Council. Payment Card Industry Data Security Standard (PCI DSS). Requirements and Testing Procedures. Version 4.0 [Электронный ресурс]. — 2022. — URL: <https://www.pcisecuritystandards.org> (дата обращения: 22.04.2026).

3.2 Wazuh Documentation. Official documentation for Wazuh 4.14 [Электронный ресурс]. — URL: <https://documentation.wazuh.com/current/> (дата обращения: 20.04.2026).

3.3 Suricata User Guide. Version 8.0.5 [Электронный ресурс]. — OISF, 2024. — URL: <https://suricata.readthedocs.io> (дата обращения: 20.04.2026).

3.4 MITRE ATT&CK Framework. Enterprise Matrix v14 [Электронный ресурс]. — MITRE Corporation, 2024. — URL: <https://attack.mitre.org> (дата обращения: 10.05.2026).

3.5 М.Видео-Эльдорадо. Годовой отчёт 2025 [Электронный ресурс]. — М., 2025. — URL: <https://ir.mvideoeldorado.ru> (дата обращения: 18.05.2026).

3.6 Emerging Threats. Suricata Ruleset ET Open Documentation [Электронный ресурс]. — URL: <https://rules.emergingthreats.net> (дата обращения: 20.04.2026).

					КТЗС.ДП.БП412.07 ПЗ	Лист
						47
Изм.	Лист	№ докум.	Подпись	Дата		

3.7 Positive Technologies. Актуальные киберугрозы. Итоги 2024 года [Электронный ресурс]. — М.: Positive Technologies, 2025. — URL: <https://www.ptsecurity.com/ru-ru/research/analytics/> (дата обращения: 12.05.2026).

3.8 OpenSearch Documentation. Index State Management [Электронный ресурс]. — URL: <https://opensearch.org/docs/latest/im-plugin/ism/index/> (дата обращения: 20.04.2026).

Приложение А

Фрагмент Lua-скрипта мониторинга системного журнала аутентификации (monitor_auth.lua)

```
function get_failed_logins()
    local out = read_cmd("journalctl _COMM=sshd --since '10 minutes ago' -q --no-pager 2>/dev/null")
    local failed = {}
    for line in out:gmatch("[^\n]+") do
        if line:find("Failed password") or line:find("Invalid user") then
            local ip = line:match("from%s+(%S+)") or "127.0.0.1"
            table.insert(failed, {ip = ip, line = line:sub(-120)})
        end
    end
    return failed
end

function get_ssh_keys_info()
    local f = io.open(os.getenv("HOME") .. "/.ssh/authorized_keys", "r")
    if not f then return nil end
    local data = f:read("*a")
    f:close()
    return {size = #data, lines = select(2, data:gsub("\n", "\n"))}
end

function check_anomalies(data, prev_keys)
    local anomalies = {}

    local root_sessions = {}
    for _, s in ipairs(data.ssh_sessions) do
        if s.user == "root" then table.insert(root_sessions, s) end
    end
    if #root_sessions > 0 then
        local ips = {}
        for _, s in ipairs(root_sessions) do table.insert(ips, s.ip) end
        table.insert(anomalies, {
            severity = "HIGH",
            type = "ROOT_SESSIONS",
            description = "Неожиданные сессии root: " .. #root_sessions .. " (лидер IP " .. (top_ip or "?") .. ": " .. top_count .. ")"
        })
    end

    if #data.failed_logins > MAX_FAILED then
        local ip_counts = {}
        for _, f in ipairs(data.failed_logins) do
            ip_counts[f.ip] = (ip_counts[f.ip] or 0) + 1
        end
        local top_ip, top_count = nil, 0
        for ip, c in pairs(ip_counts) do
            if c > top_count then top_ip, top_count = ip, c end
        end
        table.insert(anomalies, {
            severity = "HIGH",
            type = "FAILED_LOGINS",
            description = "Неудачных входов: " .. #data.failed_logins .. " (лидер IP " .. (top_ip or "?") .. ": " .. top_count .. ")"
        })
    end

    if prev_keys and data.keys_info then
        if prev_keys.size ~= data.keys_info.size then
            table.insert(anomalies, {
                severity = "CRITICAL",
                type = "AUTH_KEYS_CHANGED",
                description = "authorized_keys изменён! Препжний размер: " .. prev_keys.size .. ", новый: " .. data.keys_info.size
            })
        end
    end

    return anomalies
end
```

Приложение Б

Фрагмент программного кода валидации JWT-токена при установке WSS-соединения

```
function startWSS(server) {
  const wss = new WebSocket.Server({ server, path: "/ws" });
  wss.on("connection", (ws, req) => {
    const clientId = uuidv4();
    const ip = req.headers['x-forwarded-for'] || req.socket.remoteAddress;

    clients.set(ws, { id: clientId, ip, authenticated: false });
    addLog("server", "info", "WS client connected (awaiting auth)", { clientId, ip });

    const authTimer = setTimeout(() => {
      if (!clients.get(ws)?.authenticated) {
        ws.close(4001, "Auth timeout");
      }
    }, 10000);

    ws.on("message", async (raw) => {
      try {
        const msg = JSON.parse(raw.toString());
        const client = clients.get(ws);

        if (msg.event === "auth") {
          const { token, nonce, username } = msg.data || {};

          if (!token || !nonce) {
            ws.send(JSON.stringify({ event: "auth_error", data: { error: "Missing token or nonce" } }));
            return;
          }

          if (usedNonces.has(nonce)) {
            ws.close(4002, "Replay detected");
            return;
          }

          if (token === WSS_SECRET_TOKEN) {
            usedNonces.add(nonce);
            client.authenticated = true;
            client.username = username || "admin";
            client.connectedAt = new Date().toISOString();
            clearTimeout(authTimer);

            ws.send(JSON.stringify({
              event: "auth_success",
              data: { clientId, model: activeModel, clientIp: ip, username: client.username, connectedAt: client.connectedAt }
            }));

            addLog("server", "info", `WS client authenticated: ${client.username}`, { clientId, ip });

            ws.send(JSON.stringify({ event: "active_connections", data: getActiveConnectionsList() }));
            broadcast({ event: "active_connections", data: getActiveConnectionsList() });
            ws.send(JSON.stringify({ event: "stats", data: { ...db.getStats(), connectedClients: clients.size } }));
            ws.send(JSON.stringify({ event: "incidents_list", data: incidents.slice(0, 100) }));
            ws.send(JSON.stringify({ event: "logs_list", data: serverLogs.slice(0, 200) }));
            ws.send(JSON.stringify({ event: "quarantine_updated", data: db.getQuarantinedIps() }));
            ws.send(JSON.stringify({ event: "soar_settings_updated", data: soarSettings }));
          } else {
            ws.send(JSON.stringify({ event: "auth_error", data: { error: "Invalid token" } }));
          }
        }
      } catch (err) {
        logger.error('WS auth/message processing error', err);
      }
    });
  });
}
```

					КТЗС.ДП.БП412.07 ПЗ	Лист
						50
Изм.	Лист	№ докум.	Подпись	Дата		

Приложение В

Фрагмент класса управления белыми списками (Whitelist Manager)

```
const fs = require('fs');
const { execSync } = require('child_process');

class WhitelistManager {
  constructor() {
    this.whitelistPath = './config/static_whitelist.json';
    this.activeAdminIps = this.discoverActiveSshSessions();
  }

  discoverActiveSshSessions() {
    const foundIps = new Set();
    try {
      const sessionData = execSync('who').toString();
      const ipPattern = /\s([0-9]{1,3}\.){3}[0-9]{1,3}\s/g;
      let match;

      while ((match = ipPattern.exec(sessionData)) !== null) {
        foundIps.add(match[1]);
      }
    } catch (error) {
      console.error('[WARN] Ошибка чтения активных SSH сессий');
    }
    return Array.from(foundIps);
  }

  isIpBannable(targetIp) {
    // Рубеж 1: Безусловная защита локального интерфейса
    if (targetIp === '127.0.0.1' || targetIp.startsWith('127.0.0.1')) {
      return false;
    }

    // Рубеж 2: Защита от самоблокировки активного сеанса
    this.activeAdminIps = this.discoverActiveSshSessions();
    if (this.activeAdminIps.includes(targetIp)) {
      return false;
    }

    // Рубеж 3: Проверка статических доверенных IP
    const configData = JSON.parse(fs.readFileSync(this.whitelistPath, 'utf8'));
    if (configData.trusted_ips.includes(targetIp)) {
      return false;
    }

    return true; // Адрес может быть заблокирован
  }
}
```

Изм.	Лист	№ докум.	Подпись	Дата

Приложение Г

Фрагмент программной реализации подсистемы Startup Active Defense (модули контроля целостности и ограничения прав доступа)

```
// Контроль целостности и ограничение прав доступа к критическим файлам
function auditSelfPermissions() {
  const os = require("os");
  const fs = require("fs");
  const crypto = require("crypto");

  const targetFiles = [
    path.join(__dirname, "..", ".env"),
    path.join(__dirname, "server.js")
  ];

  targetFiles.forEach(filepath => {
    if (!fs.existsSync(filepath)) return;
    const filename = path.basename(filepath);

    // 1. Ограничение прав доступа (Unix Permissions Lockdown)
    if (os.platform() !== "win32") {
      try {
        const stats = fs.statSync(filepath);
        const mode = stats.mode;
        // Если группа или другие пользователи имеют любые права доступа (маска 0077)
        if ((mode & 0o077) !== 0) {
          fs.chmodSync(filepath, 0o600); // 0600 - только чтение/запись владельцу
          addIncident("HIGH", "SelfProtection", "INSECURE_FILE_PERMISSIONS",
            `Права доступа файла ${filename} автоматически изменены на 0600.`
          );
        }
      } catch (e) {
        logger.error(`[Self-Protection] Failed to correct permissions: ${e.message}`);
      }
    }

    // 2. Контроль целостности по хэш-суммам SHA-256
    try {
      const fileBuffer = fs.readFileSync(filepath);
      const hash = crypto.createHash("sha256").update(fileBuffer).digest("hex");
      const oldHash = integrityHashes[filename];

      if (!oldHash) {
        integrityHashes[filename] = hash;
      } else if (oldHash !== hash) {
        addIncident("CRITICAL", "SelfProtection", "SELF_TAMPERING_ATTEMPT",
          `НАРУШЕНИЕ ЦЕЛОСТНОСТИ! Обнаружено изменение файла ${filename}.`
        );
        integrityHashes[filename] = hash;
      }
    } catch (e) {
      logger.error(`[Self-Protection] Failed to verify hash: ${e.message}`);
    }
  });
}
```

					КТЗС.ДП.БП412.07 ПЗ	Лист
						52
Изм.	Лист	№ докум.	Подпись	Дата		

Приложение Д

Программный код интерактивного аудита соответствия (Compliance Dashboard)

```
const express = require('express');
const { execSync } = require('child_process');
const router = express.Router();

router.get('/api/hardening-compliance', (req, res) => {
  const checks = [
    {
      id: 'aslr',
      name: 'Рандомизация адресного пространства (ASLR)',
      execute: () => {
        const aslr = execSync('cat /proc/sys/kernel/randomize_va_space').toString().trim();
        return aslr === '2'
          ? { status: 'PASS', detail: 'ASLR полностью активен.' }
          : { status: 'FAIL', mitigation: 'sysctl -w kernel.randomize_va_space=2' };
      }
    },
    {
      id: 'ufw_status',
      name: 'Состояние системного брандмауэра UFW',
      execute: () => {
        const ufw = execSync('sudo ufw status').toString();
        return ufw.includes('active')
          ? { status: 'PASS', detail: 'Межсетевой экран запущен.' }
          : { status: 'FAIL', mitigation: 'sudo ufw enable' };
      }
    }
  ];

  const results = checks.map(checkItem => {
    try {
      return { id: checkItem.id, name: checkItem.name, ...checkItem.execute() };
    } catch (error) {
      return { id: checkItem.id, status: 'WARN', detail: 'Ошибка выполнения проверки' };
    }
  });

  res.status(200).json(results);
});

module.exports = router;
```

Приложение Е

Фрагмент программного кода генерации боевой нагрузки симулятора Mistral Demo

```
def run_apl_attack(step_by_step=False):
    print_header()
    print_color(f" [ MISTRAL APT ATTACK SIMULATION - {'ПОШАГОВЫЙ РЕЖИМ' if step_by_step else 'ЭКСПРЕСС-РЕЖИМ'} ]", "red")
    print(f" Target: {BASE_URL}")
    print(f" Attacker IP: {ATTACKER_IP}")
    print()

    print_color("\n=== [ФАЗА 1] СБОР ИНФОРМАЦИИ И СКАНИРОВАНИЕ ПОРТОВ (RECON) ===", "cyan")
    simulate_progress(f"Сканирование сети с IP {ATTACKER_IP}", 2)
    for i in range(1, 4):
        api_request('/api/logs', {
            'type': 'server',
            'level': 'warn',
            'message': f'[Firewall] Port scan detected from {ATTACKER_IP} - port check {i}/3'
        })
        time.sleep(0.4)
    api_request('/api/incidents', {
        'severity': 'LOW', 'monitor': 'NetworkMonitor', 'type': 'PORT_SCAN',
        'description': f'Targeted port scan from {ATTACKER_IP}. Nmap SYN Stealth signature detected.'
    })

    print_color("\n=== [ФАЗА 2] ПОПЫТКА СКОМПРОМЕТИРОВАТЬ SSH (BRUTE-FORCE) ===", "cyan")
    simulate_progress("Выполнение Hydra SSH Brute-Force", 3)
    for i in range(1, 6):
        api_request('/api/logs', {
            'type': 'server',
            'level': 'warn',
            'message': f'[SSH] Failed password for root from {ATTACKER_IP} port 4833{i} ssh2'
        })
        time.sleep(0.3)
    api_request('/api/logs', {'type': 'server', 'level': 'error', 'message': f'[SSH] Successful login for root from {ATTACKER_IP}'})
    api_request('/api/incidents', {
        'severity': 'HIGH', 'monitor': 'AuthMonitor', 'type': 'SSH_BRUTE_FORCE_SUCCESS',
        'description': f'Multiple failed SSH logins followed by a successful root session from {ATTACKER_IP}.'
    })

    print_color("\n=== [ФАЗА 3] НАНЕСЕНИЕ УЩЕРБА И ШИФРОВАНИЕ ДАННЫХ (RANSOMWARE) ===", "cyan")
    send_metric_spike(100, 96, 99) # имитация критической загрузки CPU
    simulate_progress("Массовое шифрование файлов в /var/www", 4)
    for i in range(1, 6):
        api_request('/api/logs', {'type': 'server', 'level': 'error', 'message': f'[Filemon] Mass encryption: /var/www/site_data_{i}.enc by attacker {ATTACKER_IP}'})
        time.sleep(0.3)

    api_request('/api/incidents', {
        'severity': 'CRITICAL', 'monitor': 'SystemMonitor', 'type': 'RANSOMWARE_ENCRYPTION',
        'description': f'Massive file encryption in progress. Spiked CPU resources. IP: {ATTACKER_IP}. Ransom note dropped.'
    })
    )
```

					КТЗС.ДП.БП412.07 ПЗ	Лист
						54
Изм.	Лист	№ докум.	Подпись	Дата		